Vertrag über die Verarbeitung personenbezogener Daten im Auftrag

nach Art. 28 DSGVO

Zwischen

Auftraggeber / Verantwortlicher (nachfolgend „**Verein**")

Name: _____
Anschrift: _____
Vertreten: _____
Kontakt: _____

und

Auftragnehmer / Auftragsverarbeiter (nachfolgend „**Anbieter**")

Name: Arkadiusz Weiss / Statix
Anschrift: c/o MDC#arkadiusz_weiss, Welserstraße 3, 87463 Dietmannsried
Kontakt: kontakt@statix-app.de

wird der folgende Vertrag geschlossen.

Präambel

Der Anbieter stellt dem Verein die Software „Statix" als Software-as-a-Service zur Verfügung (Live-Erfassung von Handballspielen, Statistikauswertung, Terminverwaltung, Anwesenheiten, Mannschaftskasse, Vereinsverwaltung, KI-gestützte Auswertung, öffentlicher Live-Ticker, Videofunktion einschließlich Live-Übertragung und — je nach gebuchter Stufe — automatischer Videoanalyse). Die Einzelheiten der Leistung ergeben sich aus den Allgemeinen Geschäftsbedingungen des Anbieters und der jeweiligen Leistungsbeschreibung (nachfolgend „**Hauptvertrag**").

Der Verein trägt die Daten seiner Mitglieder — insbesondere seiner Spielerinnen und Spieler — in die Software ein oder lässt sie durch die für ihn tätigen Trainerinnen und Trainer eintragen. Für diese Daten ist der Verein datenschutzrechtlich Verantwortlicher im Sinne des Art. 4 Nr. 7 DSGVO; der Anbieter verarbeitet sie ausschließlich in dessen Auftrag.

§ 1 Gegenstand, Dauer und Abgrenzung

(1) Gegenstand dieses Vertrages ist die Verarbeitung personenbezogener Daten durch den Anbieter im Auftrag des Vereins bei der Erbringung der Leistungen aus dem Hauptvertrag.

(2) Die Laufzeit dieses Vertrages entspricht der Laufzeit des Hauptvertrages. Er endet automatisch mit dessen Beendigung, ohne dass es einer gesonderten Kündigung bedarf. Die Pflichten aus § 9 (Löschung

und Rückgabe) bestehen über das Vertragsende hinaus fort.

(3) Abgrenzung. Nicht Gegenstand dieses Vertrages ist die Verarbeitung der Daten, die der Anbieter zu eigenen Zwecken als Verantwortlicher verarbeitet — insbesondere die Stammdaten der von einzelnen Personen selbst angelegten Nutzerkonten (Name, E-Mail-Adresse, Zugangsdaten), die Abrechnung sowie die Reichweitenmessung auf der Produktwebsite. Dazu gehört auch die Abwicklung kostenpflichtiger Pläne (Vertragsdaten, Rechnungsanschrift, Zahlungsstatus, Rechen-Credits) mit der Person, die den Plan bucht. Hierfür gilt die Datenschutzerklärung des Anbieters unter https://statix-app.de/datenschutz.

(4) Der Anbieter verarbeitet die Daten ausschließlich innerhalb des Anwendungsbereichs der DSGVO; zu Verarbeitungen in Drittländern siehe § 11.

§ 2 Art und Zweck der Verarbeitung, Datenarten, betroffene Personen

(1) Zweck. Bereitstellung und Betrieb der Software, namentlich: Erfassung und Auswertung von Spiel- und Trainingsdaten, Verwaltung von Kadern, Terminen, Zu- und Absagen sowie Abwesenheiten, Erstellung von Auswertungen und Berichten (einschließlich automatisiert erzeugter Textanalysen), Versand von Benachrichtigungen, Führung einer Mannschaftskasse, — sofern der Verein diese Funktion aktiviert — **Entgegennahme vom Verein hochgeladener oder mit Handykameras des Vereins live übertragener Videoaufnahmen** von Spielen und Trainingseinheiten, deren Speicherung, Aufbereitung (Segmentierung, Zusammenfügen zweier Kameraperspektiven, mitschwenkender Bildausschnitt, Einblendung des Spielstands), Verschlagwortung und Auswertung einschließlich der Bereitstellung daraus geschnittener Zusammenstellungen an einzelne Spielerinnen, — nur in der Analysestufe — **automatische Erkennung** von Personen, Ball, Bewegungsbahnen und Rückennummern im Bild sowie — ebenfalls nur auf Aktivierung — Veröffentlichung eines Spielstands über einen öffentlich abrufbaren Live-Ticker bzw. eines Livestreams.

Die Entscheidung, zu filmen, gehört nicht dazu. Bei hochgeladenen Aufnahmen nimmt die Software eine fertige Datei entgegen. Bei einer Live-Übertragung steuert die Software die Kamera eines Geräts, das der Verein dafür bereitstellt, aufstellt und koppelt — die Aufnahme beginnt und endet auf seine Anweisung. Ob, wo und wen gefilmt wird — und damit die Zulässigkeit gegenüber allen im Bild erfassten Personen — ist eine Entscheidung des Vereins als Verantwortlichem und liegt außerhalb der Weisungsbindung dieses Vertrages (§ 12).

(2) Art der Verarbeitung. Erheben, Erfassen, Organisieren, Ordnen, Speichern, Anpassen, Auslesen, Abfragen, Verwenden, Offenlegen durch Übermittlung, Verknüpfen, Einschränken, Löschen und Vernichten.

(3) Kategorien betroffener Personen.

- Spielerinnen und Spieler des Vereins, **einschließlich Minderjähriger**
- Trainerinnen, Trainer und Betreuerinnen und Betreuer
- Funktionsträger des Vereins (Vorstand, sportliche Leitung)
- Empfängerinnen und Empfänger geteilter Spielberichte und Einladungen
- Teilnehmerinnen und Teilnehmer von Umfragen
- Besucherinnen und Besucher des öffentlichen Live-Tickers
- bei aktivierter Videofunktion zusätzlich: **Spielerinnen und Spieler der gegnerischen Mannschaft, Schiedsrichter sowie Personen, die zufällig im Bildbereich der Aufnahme erscheinen**

(Zuschauer, Hallenpersonal). Diese Personen stehen in keiner Beziehung zur Software; der Verein verantwortet die Zulässigkeit der Aufnahme ihnen gegenüber (§ 12)

(4) Kategorien personenbezogener Daten.

Kategorie	**Einzeldaten**
Kaderdaten	Vor- und Nachname, Trikotnummer, Stamm- und Nebenpositionen, Torwartkennzeichen, Zugehörigkeit von/bis und Art (Stammkader, Zweitkader, Aushilfe), Zuordnung zu Mannschaft und Verein
Porträtfotos	freiwillig hochgeladenes Porträt einer Spielerin oder eines Trainers (nicht öffentlicher Speicher)
Kassendaten	Strafenkatalog, einzelnen Personen zugeordnete Strafen mit Grund, Betrag, Datum und Zahlungsvermerk; Trikotausgaben
Personendaten auf Vereinsebene	Vor- und Nachname, **Geburtsdatum** (optional), mannschaftsübergreifende Laufbahn
Spieldaten	Einzelereignisse eines Spiels (Tore, Würfe einschließlich Wurfposition, Wurfart und Laufweg, Paraden, Zeitstrafen, Karten, Wechsel, Spielzeiten), Kaderaufstellungen und Positionsprotokoll, Ergebnisse
Termin- und Anwesenheitsdaten	Zu- und Absagen, Freitextkommentare zur Absage, Anwesenheit bei Trainings und Spielen
Abwesenheitsdaten	Art der Abwesenheit (Urlaub, **Krankheit**, **Verletzung**, Arbeit/Schule, Privat), Zeitraum, Freitextnotiz, regelmäßige wöchentliche Abwesenheiten, Grund einer einzelnen Absage
Kontodaten von Zugängen	Name, E-Mail-Adresse, Passwort-Hashwert, Rolle, Zeitpunkt der E-Mail-Bestätigung
Kommunikationsdaten	E-Mail-Adressen von Einladungen und Berichtsfreigaben, Push-Abonnements (Endpunkt, Schlüssel, Geräte-Kennung des Browsers)
Umfragedaten	vom Verein selbst definierte Fragen und die zugehörigen Antworten
Protokoll- und Nutzungsdaten	Fehlerprotokolle (aufgerufene Adresse, Route, Browser-Kennung, Konto-Kennung), Zähler zur Missbrauchsabwehr einschließlich IP-Adresse, Zählung der Ticker-Zugriffe über ein zufälliges Sitzungsmerkmal
Bilddaten	Vereins- und Mannschaftswappen, Logos von Gegnern und Sponsoren
Videodaten	Bewegtbildaufnahmen von Spielen und Trainings, die der Verein hochlädt oder mit seinen Handykameras live überträgt, einschließlich Tonspur (bei Live-Übertragungen vom Verein abschaltbar); daraus abgeleitete Segmentdateien, Panorama- und Schwenkfassungen, Fassungen mit eingeblendetem Spielstand, Standbilder zur Kalibrierung; vom Trainerstab aufgezeichnete Besprechungen mit Zeichnungen und Mikrofonton
Videobezogene Auswertungsdaten	Verschlagwortung einzelner Szenen (Zeitabschnitt, Art der Aktion, beteiligte Spielerinnen, Bewertung, Freitextnotiz), gespeicherte Filterfragen, an einzelne Spielerinnen gerichtete Zusammenstellungen samt Zeitpunkt des Öffnens und Rückmeldung

Kategorie	Einzeldaten
Automatisch erzeugte Analysedaten (nur Analysestufe)	Personen- und Ballpositionen im Bild, Bewegungsbahnen, Laufdistanzen und Geschwindigkeiten, erkannte Rückennummern, ein Erscheinungsmerkmal zur Unterscheidung von Personen **innerhalb einer Aufnahme** (ohne Namen, nicht aufnahmeübergreifend), Bildmarkierungen der Mannschaft zum Nachtrainieren ihrer Erkennungsmodelle sowie diese Modelle selbst
Live-Übertragungsdaten	Kopplungs- und Gerätedaten der Handykameras (zufällige Gerätekennung, Akkustand, Ausrichtung), Zeitstempel der Teilstücke; Zählung der Zuschauer über eine zufällige Sitzungskennung

(5) Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO). Die Software erlaubt es dem Verein, Abwesenheiten mit der Kennzeichnung „Krankheit" oder „Verletzung" zu erfassen sowie Freitextnotizen und Absagekommentare zu hinterlegen. Dabei handelt es sich um **Gesundheitsdaten**. Der Verein stellt sicher, dass für deren Verarbeitung ein Erlaubnistatbestand nach Art. 9 Abs. 2 DSGVO vorliegt (§ 12 Abs. 3). Der Anbieter trifft für diese Daten die in Anlage 1 beschriebenen zusätzlichen Maßnahmen, insbesondere die Beschränkung der Sichtbarkeit auf den Trainerstab und die betroffene Person selbst.

Keine biometrische Identifizierung. Die automatische Videoanalyse erkennt keine Gesichter. Das Erscheinungsmerkmal dient nur dazu, innerhalb **einer** Aufnahme zu erkennen, ob es sich um dieselbe Person wie wenige Sekunden zuvor handelt; es wird weder mit einem Namen gespeichert noch über Aufnahmen hinweg verglichen. Welche Person zu einer Bewegungsbahn gehört, entscheidet der Trainerstab; die Anwendung schlägt dafür allenfalls die erkannte Rückennummer vor. Eine Verarbeitung biometrischer Daten zur eindeutigen Identifizierung im Sinne des Art. 9 Abs. 1 DSGVO findet nicht statt.

(6) Minderjährige. Dem Anbieter ist bekannt, dass die verarbeiteten Daten regelmäßig solche von Kindern und Jugendlichen umfassen. Er berücksichtigt dies bei der Gestaltung der Voreinstellungen; namentlich zeigt der öffentliche Live-Ticker Namen in der Voreinstellung nur abgekürzt an, ist ein Livestream nur nach ausdrücklicher Freigabe öffentlich und lassen sich Zuschauerbereiche im Livestream unscharf stellen (Anlage 1 Ziffer 5).

§ 3 Weisungsrecht des Vereins

(1) Der Anbieter verarbeitet die personenbezogenen Daten ausschließlich auf dokumentierte Weisung des Vereins, einschließlich in Bezug auf die Übermittlung in Drittländer, sofern er nicht durch das Unionsrecht oder das Recht eines Mitgliedstaats zu einer anderen Verarbeitung verpflichtet ist. In einem solchen Fall teilt der Anbieter dem Verein diese rechtlichen Anforderungen vor der Verarbeitung mit, sofern das betreffende Recht eine solche Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet (Art. 28 Abs. 3 lit. a DSGVO).

(2) Die Weisungen sind abschließend in diesem Vertrag und im Hauptvertrag festgelegt. Einzelweisungen erteilt der Verein in Textform an die in § 4 Abs. 4 genannte Kontaktstelle. Die Bedienung der Software durch die Nutzerinnen und Nutzer des Vereins im Rahmen des vorgesehenen Funktionsumfangs gilt als Weisung; hierzu zählt insbesondere die Entscheidung darüber, welche Daten erfasst, welche Auswertungen erzeugt und ob und in welcher Form ein Live-Ticker veröffentlicht wird.

(3) Der Anbieter informiert den Verein unverzüglich, wenn er der Auffassung ist, dass eine Weisung gegen die DSGVO oder andere Datenschutzbestimmungen verstößt. Er ist berechtigt, die Durchführung der

betreffenden Weisung auszusetzen, bis der Verein sie bestätigt oder ändert (Art. 28 Abs. 3 Satz 2 DSGVO).

§ 4 Pflichten des Anbieters

(1) Vertraulichkeit. Der Anbieter verpflichtet alle zur Verarbeitung befugten Personen zur Vertraulichkeit, soweit diese nicht bereits einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen (Art. 28 Abs. 3 lit. b DSGVO). Er stellt sicher, dass diese Personen die Daten nur auf Weisung verarbeiten (Art. 29 DSGVO).

(2) Beschränkung des Personenkreises. Zugang zu den Produktivsystemen erhalten ausschließlich Personen, die ihn zur Erbringung der vertraglichen Leistungen benötigen. Derzeit ist das ausschließlich der Anbieter selbst (eine Person, Betrieb und Entwicklung).

(3) Verzeichnis von Verarbeitungstätigkeiten. Der Anbieter führt ein Verzeichnis aller Kategorien von Verarbeitungstätigkeiten, die er im Auftrag des Vereins durchführt (Art. 30 Abs. 2 DSGVO), und stellt es dem Verein auf Anfrage zur Verfügung.

(4) Kontaktstelle. Ansprechstelle für alle Datenschutzangelegenheiten aus diesem Vertrag ist **kontakt@statix-app.de**. Ein Datenschutzbeauftragter ist beim Anbieter nicht bestellt, da die Voraussetzungen des Art. 37 DSGVO und des § 38 BDSG nicht vorliegen.

(5) Berichtigung, Einschränkung, Löschung. Der Anbieter berichtigt, löscht oder schränkt die Verarbeitung der Daten nur nach Weisung des Vereins ein. Soweit die Software dem Verein die entsprechenden Funktionen selbst bereitstellt, nimmt er diese Handlungen eigenständig vor.

§ 5 Technische und organisatorische Maßnahmen

(1) Der Anbieter trifft die zur Gewährleistung eines dem Risiko angemessenen Schutzniveaus erforderlichen technischen und organisatorischen Maßnahmen nach Art. 32 DSGVO. Die zum Zeitpunkt des Vertragsschlusses getroffenen Maßnahmen sind in **Anlage 1** beschrieben und Bestandteil dieses Vertrages.

(2) Die Maßnahmen unterliegen dem technischen Fortschritt. Der Anbieter darf sie weiterentwickeln, solange das vereinbarte Schutzniveau nicht unterschritten wird. Wesentliche Änderungen dokumentiert er und teilt sie dem Verein auf Anfrage mit.

§ 6 Unterauftragsverarbeiter

(1) Allgemeine Genehmigung. Der Verein erteilt dem Anbieter die allgemeine Genehmigung zur Hinzuziehung weiterer Auftragsverarbeiter (Art. 28 Abs. 2 Satz 2 DSGVO). Die bei Vertragsschluss eingesetzten Unterauftragsverarbeiter sind in **Anlage 2** abschließend aufgeführt und werden hiermit genehmigt.

(2) Änderungen. Der Anbieter informiert den Verein mindestens **30 Tage** vor der Beauftragung eines weiteren oder der Ersetzung eines bestehenden Unterauftragsverarbeiters in Textform. Der Verein kann der Änderung innerhalb dieser Frist aus wichtigem, datenschutzrechtlich begründetem Anlass widersprechen. Widerspricht er, ist der Anbieter berechtigt, den Hauptvertrag mit einer Frist von einem Monat zu kündigen, wenn die Leistung ohne den betreffenden Unterauftragsverarbeiter nicht zumutbar erbracht werden kann.

(3) Weitergabe der Pflichten. Der Anbieter verpflichtet jeden Unterauftragsverarbeiter vertraglich auf im Wesentlichen dieselben Datenschutzpflichten, wie sie in diesem Vertrag festgelegt sind, insbesondere auf hinreichende Garantien für geeignete technische und organisatorische Maßnahmen (Art. 28 Abs. 4 DSGVO). Kommt ein Unterauftragsverarbeiter seinen Datenschutzpflichten nicht nach, haftet der Anbieter gegenüber dem Verein für dessen Einhaltung.

(4) Keine Unterauftragsverarbeitung im Sinne dieser Regelung sind Nebenleistungen, die der Anbieter bei Dritten in Anspruch nimmt, ohne dass diese Zugriff auf die Auftragsdaten erhalten (z. B. Telekommunikations- oder Reinigungsleistungen).

§ 7 Unterstützung bei Betroffenenrechten

(1) Der Anbieter unterstützt den Verein mit geeigneten technischen und organisatorischen Maßnahmen nach Möglichkeit dabei, seiner Pflicht zur Beantwortung von Anträgen betroffener Personen auf Wahrnehmung ihrer Rechte nach Kapitel III der DSGVO nachzukommen (Art. 28 Abs. 3 lit. e DSGVO) — Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit und Widerspruch.

(2) Wendet sich eine betroffene Person unmittelbar an den Anbieter, leitet er das Anliegen unverzüglich an den Verein weiter und beantwortet es nicht selbst, es sei denn, der Verein weist ihn hierzu an.

(3) Soweit die Software dem Verein die zur Beantwortung erforderlichen Funktionen bereitstellt, erfüllt der Anbieter seine Unterstützungspflicht durch deren Bereitstellung. Darüber hinausgehende Unterstützung erbringt er unentgeltlich.

§ 8 Unterstützung bei Sicherheit, Meldepflichten und Folgenabschätzung

(1) Der Anbieter unterstützt den Verein bei der Einhaltung der in den Art. 32 bis 36 DSGVO genannten Pflichten, unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen (Art. 28 Abs. 3 lit. f DSGVO).

(2) Verletzung des Schutzes personenbezogener Daten. Der Anbieter meldet dem Verein jede ihm bekannt gewordene Verletzung des Schutzes personenbezogener Daten, die die Auftragsdaten betrifft, **unverzüglich, spätestens jedoch innerhalb von 48 Stunden** nach Kenntniserlangung, damit der Verein seine Frist nach Art. 33 Abs. 1 DSGVO wahren kann. Die Meldung enthält mindestens die nach Art. 33 Abs. 3 DSGVO erforderlichen Angaben, soweit sie dem Anbieter vorliegen.

(3) Der Anbieter unterstützt den Verein auf Anfrage bei einer Datenschutz-Folgenabschätzung (Art. 35 DSGVO) und einer vorherigen Konsultation der Aufsichtsbehörde (Art. 36 DSGVO), indem er die erforderlichen Informationen über die von ihm eingesetzten Verfahren und Maßnahmen bereitstellt.

§ 9 Löschung und Rückgabe nach Abschluss der Verarbeitung

(1) Nach Beendigung des Hauptvertrages löscht der Anbieter alle im Auftrag verarbeiteten personenbezogenen Daten oder gibt sie zurück — **nach Wahl des Vereins** (Art. 28 Abs. 3 lit. g DSGVO). Der Verein teilt seine Wahl innerhalb von 30 Tagen nach Vertragsende mit; trifft er keine Wahl, werden die Daten gelöscht.

(2) Rückgabe. Auf Verlangen stellt der Anbieter die Daten des Vereins in einem strukturierten, gängigen und maschinenlesbaren Format bereit. Die Bereitstellung erfolgt innerhalb von 30 Tagen nach Zugang des Verlangens.

(3) Löschung. Die Löschung erfolgt spätestens 90 Tage nach Vertragsende und umfasst auch Sicherungskopien nach Maßgabe der jeweiligen Sicherungszyklen. Bestehende Löschfristen während der Vertragslaufzeit ergeben sich aus Anlage 1 Ziffer 6.

(3a) Ende einer Video-Stufe. Endet die gebuchte Video-Stufe, ohne dass der Hauptvertrag endet, kann der Verein vorhandene Videoaufnahmen noch 30 Tage herunterladen. Der Anbieter kündigt die Löschung beim Ende der Stufe und sieben Tage vor der Löschung per E-Mail an; danach werden die Aufnahmen samt abgeleiteter Dateien endgültig gelöscht (Anlage 1 Ziffer 6.1).

(4) Ausnahme. Von der Löschungspflicht ausgenommen sind Daten, für die eine gesetzliche Aufbewahrungspflicht besteht. Diese Daten werden für die Dauer der Aufbewahrungspflicht in ihrer Verarbeitung eingeschränkt.

§ 10 Nachweise und Überprüfungen

(1) Der Anbieter stellt dem Verein alle erforderlichen Informationen zum Nachweis der Einhaltung der in Art. 28 DSGVO niedergelegten Pflichten zur Verfügung und ermöglicht Überprüfungen — einschließlich Inspektionen —, die vom Verein oder einem von diesem beauftragten Prüfer durchgeführt werden, und trägt zu diesen bei (Art. 28 Abs. 3 lit. h DSGVO).

(2) Der Nachweis kann geführt werden durch Vorlage dieser Anlagen, durch Selbstauskunft, durch Vorlage der Zertifizierungen oder Prüfberichte der eingesetzten Unterauftragsverarbeiter oder durch aktuelle Testate unabhängiger Stellen.

(3) Vor-Ort-Kontrollen sind mit angemessener Vorankündigung von mindestens zwei Wochen, während der üblichen Geschäftszeiten und ohne Störung des Betriebsablaufs durchzuführen. Sie finden höchstens einmal jährlich statt; bei konkretem Anlass — insbesondere nach einer Verletzung des Schutzes personenbezogener Daten — auch häufiger.

§ 11 Verarbeitung in Drittländern

(1) Die Speicherung der Auftragsdaten erfolgt in der Europäischen Union (siehe Anlage 2). Auch die Aufbereitung und Analyse von Videoaufnahmen findet ausschließlich in Rechenzentren in der Europäischen Union statt (Anlage 2 Ziffern 3 bis 5). Mehrere Unterauftragsverarbeiter haben ihren Sitz in den USA; ein Zugriff aus einem Drittland ist dort im Rahmen von Betrieb und Support möglich und nach Absatz 3 abgesichert.

(2) Eine planmäßige Übermittlung in ein Drittland findet ausschließlich bei der Nutzung der KI-gestützten Textauswertung statt und nur, wenn der Verein diese Funktion nutzt. Videobilder werden dabei nicht übermittelt. Übermittelt werden dabei **keine Klarnamen**: Die Anwendung ersetzt vor jeder Übermittlung sämtliche Namen der Spielerinnen und Spieler durch bedeutungsfreie Kennungen ([[P1]], [[P2]], …); die Zuordnung verbleibt in der Datenbank in der Europäischen Union und wird erst bei der Anzeige im Browser des Vereins wieder aufgelöst (Anlage 1 Ziffer 5).

(3) Rechtsgrundlage der Übermittlung sind das EU-US Data Privacy Framework, soweit der jeweilige Empfänger zertifiziert ist, im Übrigen die Standardvertragsklauseln der Europäischen Kommission (Durchführungsbeschluss (EU) 2021/914) nebst ergänzenden Maßnahmen. Einzelheiten in Anlage 2.

(4) Der Verein kann die KI-gestützte Auswertung auf Anfrage an die Kontaktstelle nach § 4 Abs. 4 für eine Mannschaft oder den ganzen Verein vollständig deaktivieren lassen. In diesem Fall findet keine

Drittlandübermittlung statt.

§ 12 Pflichten des Vereins

(1) Rechtmäßigkeit. Der Verein ist für die Rechtmäßigkeit der Verarbeitung und für die Wahrung der Rechte der betroffenen Personen verantwortlich. Er stellt sicher, dass für jede von ihm veranlasste Verarbeitung eine Rechtsgrundlage besteht.

(2) Informationspflichten. Der Verein informiert die betroffenen Personen — bei Minderjährigen deren Erziehungsberechtigte — über die Verarbeitung ihrer Daten in der Software nach Art. 13 und 14 DSGVO. Der Anbieter stellt hierfür ein Muster-Informationsblatt zur Verfügung; dessen Verwendung entbindet den Verein nicht von der eigenen Prüfung.

(3) Besondere Datenkategorien. Erfasst der Verein Abwesenheiten mit der Kennzeichnung „Krankheit" oder „Verletzung" oder hinterlegt er Gesundheitsangaben in Freitextfeldern, stellt er sicher, dass hierfür ein Erlaubnistatbestand nach Art. 9 Abs. 2 DSGVO vorliegt.

(4) Öffentlicher Live-Ticker und Livestream. Veröffentlicht der Verein einen Live-Ticker oder einen Livestream, verantwortet er die damit verbundene Offenlegung. Für einen öffentlichen Livestream gilt das auch gegenüber allen Personen im Bild und im Ton; der Verein nutzt dafür die angebotenen Mittel (Ton abschalten oder auf Hallenton beschränken, Bereiche unscharf stellen, Übertragung nur für Angemeldete). Er stellt sicher, dass die gewählte Namensdarstellung (voller Name, abgekürzt oder nur Trikotnummer) der Rechtsgrundlage entspricht, auf die er sich stützt. Für die Anzeige der vollen Namen Minderjähriger ist regelmäßig eine Einwilligung der Erziehungsberechtigten erforderlich.

(5) Umfragen und Freitexte. Der Verein verantwortet den Inhalt der von ihm erstellten Umfragen und der von seinen Nutzerinnen und Nutzern eingegebenen Freitexte.

(6) Videoaufnahmen und Live-Übertragung. Der Verein entscheidet, ob er filmt, und schafft die Rechtsgrundlage gegenüber allen aufgenommenen Personen — den eigenen Spielerinnen (bei Minderjährigen regelmäßig Einwilligung der Erziehungsberechtigten), Gegnerinnen und Gegnern, Schiedsrichtern und Zuschauern. Er beachtet die Vorgaben des Hallenbetreibers und des Verbands. Er prüft, ob für systematische Aufnahmen und — in der Analysestufe — die automatische Auswertung eine Datenschutz-Folgenabschätzung (Art. 35 DSGVO) erforderlich ist; der Anbieter unterstützt ihn dabei nach § 8 Abs. 3.

(7) Zugangsdaten. Der Verein hält seine Nutzerinnen und Nutzer zu sorgfältigem Umgang mit Zugangsdaten, Einladungslinks und Beitrittscodes an und entzieht ausgeschiedenen Personen den Zugang unverzüglich.

§ 13 Haftung

(1) Für die Haftung der Parteien untereinander gelten die Regelungen des Hauptvertrages, soweit dieser Vertrag nichts anderes bestimmt.

(2) Art. 82 DSGVO bleibt unberührt.

§ 14 Schlussbestimmungen

(1) Änderungen und Ergänzungen dieses Vertrages einschließlich seiner Anlagen bedürfen der Schriftform; elektronische Form nach Art. 28 Abs. 9 DSGVO genügt.

(2) Bei Widersprüchen zwischen diesem Vertrag und dem Hauptvertrag geht dieser Vertrag in datenschutzrechtlichen Fragen vor.

(3) Sollte eine Bestimmung dieses Vertrages unwirksam sein oder werden, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt. Die Parteien ersetzen die unwirksame Bestimmung durch eine wirksame, die dem wirtschaftlichen Zweck am nächsten kommt.

(4) Es gilt das Recht der Bundesrepublik Deutschland.

(5) Bestandteile dieses Vertrages sind:

- **Anlage 1** — Technische und organisatorische Maßnahmen (Art. 32 DSGVO)
- **Anlage 2** — Unterauftragsverarbeiter

Unterschriften

Ort, Datum: _____ Ort, Datum: _____

_____ _____

Für den Verein Für den Anbieter

_____ Arkadiusz Weiss / Statix

Entwurfsstand: 12.11.2026 · Version 0.4 · nicht anwaltlich geprüft

Anlage 1 — Technische und organisatorische Maßnahmen

zum Auftragsverarbeitungsvertrag nach Art. 28 DSGVO · Art. 32 DSGVO

Der Anbieter betreibt die Software als Software-as-a-Service auf der Infrastruktur der in Anlage 2 genannten Dienstleister. Die Maßnahmen gliedern sich nach Art. 32 Abs. 1 DSGVO.

---

1. Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

1.1 Zutrittskontrolle

Der Anbieter betreibt keine eigenen Rechenzentren. Der physische Zutritt zu den Systemen wird durch die eingesetzten Unterauftragsverarbeiter sichergestellt (Anlage 2); deren Rechenzentren sind nach anerkannten Standards zertifiziert (u. a. ISO 27001, SOC 2). Die Datenbank wird in Frankfurt am Main betrieben.

1.2 Zugangskontrolle (Systemzugang)

- **Authentifizierung** über Benutzername und Passwort. Passwörter werden ausschließlich als **bcrypt-Hashwert** gespeichert (Kostenfaktor 10), niemals im Klartext (app/api/auth/register/route.ts).
- **Sitzungen** werden über signierte JSON Web Tokens geführt; die Anwendung hält keine Passwörter im Speicher vor (app/api/auth/[...nextauth]/authOptions.ts).
- **E-Mail-Verifikation** vor der Nutzung; Bestätigungs- und Passwort-Zurücksetzen-Token laufen ab und werden anschließend gelöscht (email_verification_tokens, password_reset_tokens).
- **Missbrauchsabwehr:** Anmelde-, Registrierungs- und Zurücksetzen-Versuche werden in einem Zähler in der Datenbank begrenzt (auth_rate_limits, lib/auth/rate-limit.ts). Geheimnisse wie Freigabe-Token werden vor der Ablage im Zähler mit SHA-256 gehasht, damit der Zähler kein zweiter Ort wird, an dem ein gültiges Token liegt.
- **Widerruf von Sitzungen:** Jedes Konto trägt eine Sitzungsversion, die in jedem Token steht und bei jeder Anfrage verglichen wird. Passwortänderung, Zurücksetzen, vorgemerkte Kontolöschung und „Überall abmelden" erhöhen sie und entwerten damit alle bestehenden Sitzungen sofort (lib/auth/session-version.ts).
- **Einladungs-, Beitritts- und Kamera-Kopplungslinks** werden nur als SHA-256-Hashwert gespeichert (lib/auth/link-token.ts, lib/live/tokens.ts); ein Datenbankauszug enthält keinen gültigen Link.
- **Keine Nutzer-Enumeration:** Anmelde- und Zurücksetzen-Antworten unterscheiden nicht zwischen bekannter und unbekannter E-Mail-Adresse.

1.3 Zugriffskontrolle (Datenzugriff)

- **Jede** Schnittstelle der Anwendung prüft Authentifizierung **und** Berechtigung serverseitig gegen die Datenbank, bevor sie Daten liefert oder schreibt; die Prüfung ist an einer Stelle gebündelt (lib/api-route.ts, lib/auth.ts). Es gibt keinen Pfad, der die Mandantengrenze umgeht.
- **Rollenmodell:** Vereinsverwaltung (Vollzugriff im Verein), sportliche Leitung (nur lesend), Trainer (nur die eigenen Mannschaften), Spielerzugang (nur die eigenen Termine und Rückmeldungen).

- **Datenbankzugriff ausschließlich serverseitig.** Es existiert kein Datenbank-Client im Browser. Die Zugangsdaten zur Datenbank und der privilegierte Speicherschlüssel liegen ausschließlich auf dem Server (lib/prisma.ts, lib/storage/team-logo.ts).
- **Row Level Security** ist auf allen Tabellen aktiviert und enthält bewusst **keine** Freigaberegeln. Für die öffentlichen Schlüssel bedeutet das eine vollständige Sperre; ein abhandengekommener öffentlicher Schlüssel liest nichts (db/2026-07-02_lock_down_api_grants.sql, db/2026-08-19_drop_dead_rls.sql).
- **Privilegierte Datenbankfunktionen** sind den öffentlichen Rollen ausdrücklich entzogen (revoke execute … from public, anon, authenticated).
- **Videoaufnahmen sind nicht öffentlich adressierbar.** Jede Aufnahme liegt unter einer zufälligen 128-Bit-Kennung, die nicht aus der Spiel- oder Mannschaftskennung abgeleitet ist; der Speicherbereich gibt nichts ohne Signatur heraus. Ein Abruf entsteht erst, nachdem die Anwendung die Berechtigung geprüft hat, und gilt zeitlich befristet (lib/video/r2.ts, lib/video/playback.ts).
- **Porträtfotos** liegen in einem nicht öffentlichen Speicherbereich und werden nur nach Prüfung der Berechtigung ausgeliefert (lib/storage/player-photo.ts).
- **Rechenaufträge ohne Datenbankzugang.** Die Recheninstanzen für Videoaufbereitung und -analyse (Anlage 2 Ziffern 4 und 5) haben keinen Zugang zur Datenbank; sie erhalten je Auftrag nur die nötigen Dateiadressen über eine authentifizierte Schnittstelle und kennen keine Namen.
- **Eine an eine Spielerin geschickte Zusammenstellung gibt nur ihre Szenen frei.** Ausgeliefert wird ein Verzeichnis der enthaltenen Segmente, nicht die Aufnahme; das übrige Spiel ist darin nicht benannt und damit nicht abrufbar. Das ist der Grund, aus dem Aufnahmen überhaupt segmentiert werden.

1.4 Trennungskontrolle

Alle Daten tragen die Kennung der Mannschaft und, wo einschlägig, des Vereins. Jede Abfrage wird serverseitig auf die Mannschaften eingeschränkt, für die die anfragende Person eine nachgewiesene Mitgliedschaft besitzt (lib/clubs/scope.ts). Verschiedene Vereine sehen einander nicht.

---

2. Integrität (Art. 32 Abs. 1 lit. b DSGVO)

2.1 Weitergabekontrolle (Transport)

- Sämtliche Verbindungen ausschließlich über **TLS**; HTTP wird auf HTTPS umgeleitet. **HSTS** ist gesetzt (next.config.mjs).
- Sicherheitskopfzeilen: Content-Security-Policy mit Einmal-Kennung je Anfrage (middleware.ts), X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy, Permissions-Policy.
- Die öffentlichen Schnittstellen des Live-Tickers akzeptieren nur die ausdrücklich freigegebene Herkunft (lib/public/cors.ts).
- Berichts-PDFs werden **in der eigenen Laufzeitumgebung** erzeugt; es wird kein externer Konvertierungsdienst eingesetzt (lib/pdf/render-share-pdf.ts).
- **Videoaufnahmen verlassen die EU nicht.** Der Objektspeicher ist mit der Kennzeichnung jurisdiction: eu angelegt, die Speicherung und Verarbeitung an Rechenzentren in der EU bindet; die Anwendung spricht ausdrücklich den zu dieser Kennzeichnung gehörenden Zugangspunkt an, weil der Standardzugangspunkt unbemerkt auf den weltweiten Speicherbereich zugreifen würde (lib/video/r2.ts). Der Dienst, der die Aufnahmen zerlegt, läuft in Frankfurt (Anlage 2 Ziffer 4);

Recheninstanzen mit Grafikprozessor werden ausschließlich in EU-Rechenzentren angemietet (Anlage 2 Ziffer 5, lib/analysis/runpod.ts).
- **Live-Übertragung:** Die Handykameras übertragen verschlüsselt (TLS) und direkt in den Videospeicher; die Teilstücke liegen bis zur Bestätigung zusätzlich im Gerätespeicher des Handys und werden danach dort gelöscht.

2.2 Eingabekontrolle (Nachvollziehbarkeit)

- Erfasste Ereignisse, Abwesenheiten, Rückmeldungen und Analysen tragen Zeitstempel und die Kennung der erfassenden Person (created_by, responded_by_profile_id).
- Eine Rückmeldung, die ein Trainer stellvertretend für eine Spielerin abgibt, ist als solche gekennzeichnet und in der Oberfläche unterscheidbar.
- Fehler werden mit Kontext protokolliert (error_logs) und dienen der Nachvollziehbarkeit von Störungen.
- Sämtliche Eingaben werden serverseitig gegen ein Schema geprüft (lib/validation.ts, Zod).

---

3. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b, c DSGVO)

- **Verwaltetes Hosting** mit redundanter Infrastruktur der in Anlage 2 genannten Dienstleister.
- **Datensicherung:** Jede Nacht (03:30 Uhr Winterzeit, 04:30 Uhr Sommerzeit) ein vollständiger Abzug der Anwendungsdaten (pg_dump, Schema public), vor dem Ablegen auf Lesbarkeit geprüft und mit age **verschlüsselt** — den Schlüssel zum Entschlüsseln hält allein der Anbieter, auch der Speicheranbieter kann den Inhalt nicht lesen. Erzeugt auf einer Recheninstanz in Frankfurt (Anlage 2 Ziffer 4), abgelegt in einem an die EU gebundenen Speicherbereich (Anlage 2 Ziffer 3), **30 Tage** aufbewahrt und danach automatisch gelöscht. Ein fehlgeschlagener Lauf löst eine Warnmail an den Anbieter aus. Gestartet wird der Lauf über einen zeitgesteuerten Auftrag in GitHub Actions, der nur die Recheninstanz anstößt und selbst keinen Zugriff auf die Daten hat. Das Vorgehen zur Wiederherstellung ist dokumentiert (services/db-backup/README.md). In Betrieb seit: 12.11.2026 (erster erfolgreicher Lauf). [wird nachgetragen] Zusätzlich kann der Verein die Daten seiner Mannschaften jederzeit selbst als maschinenlesbares Archiv exportieren (Ziffer 6.2).
- **Offline-Fähigkeit als Ausfallschutz:** Die Live-Erfassung arbeitet vollständig lokal im Gerät weiter, wenn die Verbindung abbricht. Erfasste Ereignisse liegen bis zur Übertragung im Gerätespeicher und werden über mehrfach ausführbare (idempotente) Schnittstellen nachgereicht — ein Netzausfall in der Halle führt nicht zum Datenverlust (lib/offline/).
- **Lastgrenzen:** Für jede wachsende oder kostenverursachende Verarbeitung besteht eine konfigurierbare Obergrenze (lib/limits.ts), unter anderem für Analysen, Ereignisse je Spiel, E-Mail-Versand und Zugriffe auf den öffentlichen Live-Ticker.
- **Überwachung:** Zustandsschnittstelle (/api/health) sowie Benachrichtigung des Anbieters bei schwerwiegenden Fehlern.

---

4. Verfahren zur regelmäßigen Überprüfung und Bewertung (Art. 32 Abs. 1 lit. d DSGVO)

- **Automatisierte Prüfkette** bei jeder Änderung des Quellcodes: statische Analyse, Typprüfung, mehrere tausend automatisierte Tests, Erstellung des Produktionsstands, Prüfung der

Abhängigkeiten auf bekannte Schwachstellen sowie ein durchgehender Test der Offline-Übertragungsstrecke (.github/workflows/ci.yml).
- **Abgleich von Datenmodell und Datenbank** (npm run db:verify), um unbemerkte Abweichungen des Produktivschemas auszuschließen.
- **Sicherheitshinweise der Datenbankplattform** (Supabase Advisors) werden nach jeder Schemaänderung ausgewertet.
- **Dokumentiertes Sicherheits-Audit** der Anwendung (docs/production-readiness-audit.md, wiederholt im Oktober 2026: docs/security-audit-2026-10.md); Wiederholung monatlich sowie bei wesentlichen Änderungen.

---

5. Datenminimierung, Pseudonymisierung und datenschutzfreundliche Voreinstellungen (Art. 25, Art. 32 Abs. 1 lit. a DSGVO)

- **Pseudonymisierung vor jeder KI-Auswertung.** Vor der Übermittlung an einen KI-Dienst werden sämtliche Namen durch bedeutungsfreie Kennungen ([[P1]], [[P2]], …) ersetzt. Der übermittelte Datensatz enthält **physisch keinen Namen**. Die Zuordnung wird gemeinsam mit dem Bericht gespeichert — als reine Kennungen ohne Namen — und erst im Browser des Vereins wieder aufgelöst (ai/preprocess/pseudonymize.ts).
- **Abgekürzte Namen im öffentlichen Live-Ticker als Voreinstellung.** Der Ticker zeigt „Lena M." statt „Lena Müller", solange der Verein die Einstellung nicht bewusst ändert. Wählbar sind voller Name, abgekürzter Name oder nur die Trikotnummer. Die Voreinstellung gilt auch für bereits zuvor angelegte Mannschaften (db/2026-08-17_public_player_name_display.sql, lib/public/player-name-display.ts).
- **Begrenzte Nutzlast des öffentlichen Tickers.** Der Serialisierer gibt ausschließlich ausdrücklich freigegebene Felder aus; alles Übrige verlässt die Anwendung nicht (lib/public/live-serialize.ts).
- **Redaktion von Gesundheits- und Abwesenheitsgründen.** In der Anwesenheitsliste einer Mannschaft sehen Mitspielerinnen ausschließlich die Tatsache der Absage. Grund, Art der Abwesenheit („Krankheit", „Verletzung") und Freitextnotiz sind auf den Trainerstab und die betroffene Person selbst beschränkt — und zwar **serverseitig in der Datenabfrage**, nicht erst in der Anzeige (lib/schedule/attendance.ts).
- **Zählung der Ticker-Zugriffe ohne Personenbezug:** über eine zufällige, vom Gerät erzeugte Sitzungskennung; keine Cookies, keine IP-Speicherung (live_ticker_heartbeats).
- **Videofunktion nur auf ausdrückliche Buchung.** Sie steht einer Mannschaft nur mit einer gebuchten Video-Stufe zur Verfügung; die automatische Analyse (Personen, Ball, Rückennummern) nur in der Analysestufe. Die Prüfung erfolgt serverseitig an jeder Schnittstelle und noch einmal, bevor eine Recheninstanz einen Auftrag übernimmt (lib/billing/video-features.ts). Ein Verein, der keine Aufnahmen wünscht, erzeugt dadurch auch keine.
- **Verkleinerung der Aufnahme.** Eine hochzuladende Datei wird in der Voreinstellung bereits im Browser der hochladenden Person verkleinert (lib/video/compress.ts) oder — auf Wahl — unmittelbar nach dem Hochladen auf einer Recheninstanz in der EU; die Originaldatei wird danach gelöscht. Ausgenommen sind die beiden Hälften eines Panoramas, die für das Zusammenfügen in voller Auflösung benötigt und danach gelöscht werden, sofern der Verein ihre Aufbewahrung nicht ausdrücklich wählt.
- **Live-Übertragung datensparsam:** Ein Livestream ist nur nach ausdrücklicher Freigabe öffentlich; die Mannschaft kann den Ton vollständig abschalten oder auf Hallenton beschränken (lib/live/audio-

mode.ts, gilt für Übertragung **und** Aufzeichnung) und Bereiche wie die Tribüne unscharf stellen (lib/live/hall-areas.ts). Eine Probeübertragung wird nie öffentlich.

- **Keine Gesichtserkennung, keine Galerie.** Die automatische Analyse unterscheidet Personen nur innerhalb einer Aufnahme anhand eines Erscheinungsmerkmals, das weder mit einem Namen gespeichert noch über Aufnahmen hinweg verglichen wird (lib/analysis/reid.ts). Welche Spielerin zu einer Bewegungsbahn gehört, entscheidet der Trainerstab.
- **Nachtrainieren nur für die eigene Mannschaft.** Bildmarkierungen werden als Zeitpunkt und Rechteck gespeichert, nicht als Bild; ein nachtrainiertes Modell wird nur für die Mannschaft verwendet, deren Markierungen es enthält. Ein mannschaftsübergreifendes Modell wird nicht gebildet (docs/training.md).
- **Keine Weitergabe zu Werbezwecken.** Auftragsdaten werden nicht zu Werbezwecken verwendet und nicht an Dritte außerhalb der Anlage 2 übermittelt.

---

6. Löschkonzept (Art. 17, Art. 5 Abs. 1 lit. e DSGVO)

6.1 Automatisierte Löschung im laufenden Betrieb

Ein täglich um 03:17 Uhr laufender Datenbankauftrag löscht abgelaufene Daten (db/2026-08-17_retention.sql):

Datenart	Löschung nach
Zähler zur Missbrauchsabwehr (enthält IP-Adressen)	1 Tag
Zugriffszählung des Live-Tickers	2 Tage (regulär bereits mit Spielende)
Token für Passwort-Zurücksetzen	7 Tage nach Ablauf
Token für E-Mail-Bestätigung	7 Tage nach Ablauf
Fehlerprotokolle	90 Tage
Nachweis der KI-Nutzung (Kontingentzählung, ohne Inhalte)	400 Tage

Weitere Fristen setzt ein stündlich laufender Aufräumauftrag durch (lib/trash/purge.ts, lib/live/purge.ts):

Datenart	Löschung nach
Papierkorb: gelöschte Spiele, Kadermitglieder, Turniere, Mannschaften und Videoaufnahmen (samt Segmenten, Fassungen und Analyseergebnissen)	30 Tage
Zur Löschung vorgemerkte Nutzerkonten (Karenzzeit)	30 Tage
Teilstücke einer Probeübertragung	7 Tage nach deren Ende
Teilstücke einer Live-Übertragung (die Aufzeichnung ist dann als Aufnahme in der Bibliothek)	30 Tage nach deren Ende
Downloadfassungen mit eingebranntem Spielstand	7 Tage
Videoaufnahmen nach dem Ende einer Video-Stufe	30 Tage Downloadfrist; vorher zwei Ankündigungen per E-Mail (beim Ende und sieben Tage vor der Löschung)

6.2 Löschung auf Veranlassung

- **Einzelne Datensätze** (Spielerin, Spiel, Termin, Abwesenheit, Umfrage, Freigabe, Videoaufnahme) löscht der Verein jederzeit selbst in der Anwendung. Spiele, Kadermitglieder, Turniere, Mannschaften und Videoaufnahmen gehen zunächst für 30 Tage in einen Papierkorb und können dort vorzeitig endgültig gelöscht werden (lib/trash/).
- **Nutzerkonto:** Löschung in der Anwendung sowie über eine öffentlich zugängliche Seite für Personen ohne Zugang (/account-deletion). Das Konto wird sofort gesperrt und nach einer Karenzzeit von 30 Tagen endgültig gelöscht (lib/account/deletion-schedule.ts). Die Löschung entfernt Mannschaften, die die betreffende Person allein betreut, vollständig einschließlich der dort erfassten Spielerdaten; Mannschaften mit weiteren Trainern bleiben bestehen und werden übergeben, damit ein Verein nicht seine Saison verliert, weil eine Trainerin ihr Konto schließt (lib/account/delete-account.ts).
- **Videoaufnahmen:** Das endgültige Löschen einer Aufnahme (beim Leeren des Papierkorbs) entfernt die Ursprungsdatei **und** sämtliche daraus erzeugten Segmente und Fassungen aus dem Objektspeicher, bevor der Datenbankeintrag verschwindet — dieser Eintrag ist das Einzige, was die Segmente benennt, und eine umgekehrte Reihenfolge hinterließe Aufnahmen, die niemand mehr finden und daher auch niemand mehr löschen kann (lib/video/purge-objects.ts).
- **Datenexport:** Jedes Konto lädt seine eigenen Daten, die Cheftrainerin bzw. der Cheftrainer alle Daten der Mannschaft als maschinenlesbares Archiv herunter (lib/export/); Grundlage der Rückgabe nach § 9 Abs. 2.
- **Vereinsdaten insgesamt:** nach § 9 des Vertrages.

6.3 Sicherungskopien

Gelöschte Daten können bis zu **30 Tage** lang noch in den verschlüsselten Datensicherungen enthalten sein (Ziffer 3). Sie werden nicht in den Produktivbetrieb zurückgeführt und mit Ablauf der Aufbewahrung automatisch endgültig entfernt.

Entwurfsstand: 12.11.2026 · Version 0.4 · nicht anwaltlich geprüft

Anlage 2 — Unterauftragsverarbeiter

zum Auftragsverarbeitungsvertrag nach Art. 28 DSGVO · Art. 28 Abs. 2 und 4 DSGVO

Der Verein genehmigt mit Abschluss des Vertrages die Beauftragung der folgenden Unterauftragsverarbeiter (§ 6 Abs. 1 des Vertrages). Änderungen werden nach § 6 Abs. 2 mit einer Frist von 30 Tagen angekündigt.

---

1. Betrieb der Anwendung

Dienstleister	Vercel Inc. (Delaware, Reg.-Nr. 5857312), 440 N Barranca Ave #4133, Covina, CA 91723, USA — laut DPA, geprüft am 12.11.2026
Leistung	Betrieb der Web-Anwendung, Auslieferung der Oberfläche, Ausführung der Serverfunktionen und der zeitgesteuerten Aufträge
Datenkategorien	alle in § 2 Abs. 4 des Vertrages genannten Daten, während der Verarbeitung einer Anfrage (keine dauerhafte Speicherung). Videodateien laufen **nicht** über Vercel: Hoch- und Herunterladen gehen über befristete, signierte Adressen direkt zum Videospeicher (Ziffer 3)
Ort der Verarbeitung	**Frankfurt am Main, Deutschland** (Vercel-Funktionsregion fra1, in den Projekteinstellungen abgelesen am 12.11.2026)
Drittlandbezug	Unternehmenssitz USA; Zugriff im Rahmen von Betrieb und Support möglich
Grundlage	EU-US Data Privacy Framework, soweit der Empfänger zertifiziert ist (Registerprüfung unter dataprivacyframework.gov), im Übrigen Standardvertragsklauseln
DPA	https://vercel.com/legal/dpa — wird mit Abschluss der Vercel-Bedingungen verbindlich

2. Datenbank und Dateispeicher

Dienstleister	Supabase Pte. Ltd., 65 Chulia Street #38-02/03, OCBC Centre, Singapur 049513 — laut Terms und DPA (Version 1, 01.08.2026), geprüft am 12.11.2026. Bei Kauf über AWS Marketplace wäre es Supabase, Inc., Delaware
Leistung	PostgreSQL-Datenbank (sämtliche Anwendungsdaten außer Videodateien), Dateispeicher für Wappen und Logos sowie — in nicht öffentlichen Bereichen — Porträtfotos und Standbilder zur Kalibrierung
Datenkategorien	alle in § 2 Abs. 4 des Vertrages genannten Daten außer den Videodateien selbst
Ort der Verarbeitung	**Frankfurt am Main, Deutschland** (Region eu-central-1, am Projekt abgelesen am 11.11.2026)
Drittlandbezug	Unternehmenssitz außerhalb der EU; Zugriff im Rahmen von Betrieb und Support möglich
Grundlage	Standardvertragsklauseln nach dem DPA des Dienstleisters
DPA	https://supabase.com/legal/dpa — Bestandteil der Terms; „acceptance of the Agreement shall have the same effect as signing the SCCs“ (Ziff. 12.2)

3. Videospeicher

Dienstleister	Cloudflare, Inc., 101 Townsend Street, San Francisco, CA 94107, USA — laut DPA Version 6.4 (03.04.2026), Annex 1; eine EU-Gesellschaft als Vertragspartner nennt der DPA nicht
Leistung	Objektspeicher (Cloudflare R2) für: hochgeladene Videoaufnahmen und die daraus erzeugten Segmentdateien; die Teilstücke einer Live-Übertragung, die die Handykameras des Vereins senden; daraus erzeugte Fassungen (Panorama, mitschwenkender Ausschnitt, Fassung mit eingebranntem Spielstand); Ergebnisdateien der Videoanalyse (Bewegungsbahnen, Ballbahnen); von der Mannschaft nachtrainierte Erkennungsmodelle; die **verschlüsselten** täglichen Datenbanksicherungen (eigener Bucket, ebenfalls EU-gebunden, 30 Tage)
Datenkategorien	Videodaten nach § 2 Abs. 4 des Vertrages einschließlich Tonspur sowie videobezogene Auswertungsdaten ohne Namen; Namen und Verschlagwortung verbleiben in der Datenbank
Ort der Verarbeitung	**Europäische Union.** Der Speicherbereich ist mit der Kennzeichnung jurisdiction: eu angelegt; diese bindet Speicherung **und** Verarbeitung an Rechenzentren in der EU und ist nachträglich nicht änderbar
Drittlandbezug	Unternehmenssitz USA; Zugriff im Rahmen von Betrieb und Support möglich
Grundlage	EU-US Data Privacy Framework, soweit der Empfänger zertifiziert ist (Registerprüfung unter dataprivacyframework.gov), im Übrigen Standardvertragsklauseln
Besonderheit	Der Speicherbereich ist nicht öffentlich erreichbar. Jeder Abruf läuft über eine zeitlich befristete, signierte Adresse, die die Anwendung nach Prüfung der Berechtigung erzeugt (Anlage 1 Ziffer 1.3). Das gilt auch für Zuschauerinnen und Zuschauer eines öffentlichen Livestreams: ihr Gerät lädt die Segmente über solche Adressen direkt aus dem Speicher, wobei Cloudflare deren IP-Adresse technisch verarbeitet
DPA	https://www.cloudflare.com/cloudflare-customer-dpa/ — für Self-Serve-Konten automatisch in das Self-Serve Subscription Agreement einbezogen, keine gesonderte Unterschrift nötig (Auskunft von Cloudflare, 12.11.2026)

4. Videoaufbereitung

Dienstleister	Fly.io, Inc. [wird nachgetragen]
Leistung	Zerlegung hochgeladener Videoaufnahmen in Segmentdateien; Zusammenfügen mehrteiliger Uploads und der Teilstücke einer Live-Übertragung. Die Aufnahme wird dazu aus dem Objektspeicher gelesen und das Ergebnis dorthin zurückgeschrieben. Außerdem die tägliche Datenbanksicherung: eine eigene Recheninstanz in Frankfurt erstellt den Abzug, verschlüsselt ihn und legt ihn im Objektspeicher ab (Anlage 1 Ziffer 3)
Datenkategorien	Videodaten nach § 2 Abs. 4 des Vertrages, während der Dauer der Verarbeitung. **Keine dauerhafte Speicherung**: jede erzeugte Datei wird nach dem Zurückschreiben unverzüglich entfernt
Ort der Verarbeitung	**Frankfurt am Main, Deutschland** (Fly-Region fra). Nachprüfbar im laufenden Betrieb: die Recheninstanz gibt ihre eigene Region unter /health aus, im Feld region. Verlässt sie Frankfurt, ist diese Zeile nachzuführen
Drittlandbezug	Unternehmenssitz USA; Zugriff im Rahmen von Betrieb und Support möglich
Grundlage	EU-US Data Privacy Framework, soweit der Empfänger zertifiziert ist, im Übrigen Standardvertragsklauseln

Besonderheit	Der Dienst besitzt **keinen Zugang zur Datenbank**. Er erhält seine Aufträge über eine authentifizierte Schnittstelle der Anwendung und kennt weder Namen noch Verschlagwortung noch die Zuordnung zu einer Mannschaft
DPA	https://fly.io/legal/dpa/

5. Rechenintensive Videoverarbeitung und Videoanalyse auf Grafikprozessoren

Dienstleister	Runpod Inc. [wird nachgetragen]
Leistung	**(a)** Zusammenfügen zweier Kameraperspektiven zu einem Panorama, Verkleinern sehr großer Aufnahmen, Einrechnen der Bilddrehung, Erzeugen eines mitschwenkenden Bildausschnitts, Einbrennen des Spielstands in eine Downloadfassung; **(b)** während einer Live-Übertragung das fortlaufende Zusammenfügen der beiden Handykameras zu einem Bild einschließlich Kameraführung und Unschärfe ausgewählter Bildbereiche (z. B. Tribüne); **(c)** nur in der Analysestufe: automatische Erkennung von Personen und Ball im Bild, Bewegungsbahnen, Lesen der Rückennummern auf der Kleidung, Unterscheidung von Personen innerhalb **einer** Aufnahme anhand ihres Erscheinungsbilds sowie das Nachtrainieren der Erkennungsmodelle **für die eigene Mannschaft**
Datenkategorien	Videodaten einschließlich Tonspur, Kalibrierungsangaben, Bewegungs- und Ballbahnen ohne Namen, Bildmarkierungen der Mannschaft für das Nachtrainieren. **Keine Namen**: Die Recheninstanz kennt weder Namen noch E-Mail-Adressen noch Kaderzuordnungen. Die Zuordnung einer Bahn zu einer Spielerin trifft der Verein in der Anwendung
Ort der Verarbeitung	**Europäische Union.** Angemietet wird ausschließlich in der „Secure Cloud“ des Dienstleisters und ausschließlich in Rechenzentren in Frankreich, Rumänien, Schweden, den Niederlanden und Tschechien (lib/analysis/runpod.ts, DEFAULT_DATA_CENTER_IDS); Island und alle Rechenzentren außerhalb der EU sind ausgeschlossen
Drittlandbezug	Unternehmenssitz USA; Zugriff im Rahmen von Betrieb und Support möglich
Grundlage	Runpod-DPA „EU US UK BR – Nov 2026“ mit Standardvertragsklauseln und UK-Addendum (https://www.runpod.io/legal/data-processing-agreement). Er wird erst mit Unterzeichnung über das Trust Center (trust.runpod.io) verbindlich. [wird nachgetragen]
Besonderheit	Die Recheninstanz liest die Aufnahme über eine befristete, signierte Adresse aus dem Videospeicher (Ziffer 3) und schreibt das Ergebnis dorthin zurück. Zwischendateien liegen nur im flüchtigen Speicher der Instanz. Eine Gesichtserkennung findet nicht statt; das Erscheinungsmerkmal wird weder mit einem Namen gespeichert noch über verschiedene Aufnahmen hinweg verglichen. Die Modelle für das Lesen der Rückennummern und das Erscheinungsmerkmal laufen **auf der Instanz selbst**; es wird dafür kein weiterer Dienst angesprochen
Bedingungen	https://www.runpod.io/legal/data-processing-agreement · Datenschutz: https://www.runpod.io/legal/privacy-policy (privacy@runpod.io)

6. Transaktionaler E-Mail-Versand

Dienstleister	Brevo GmbH, Köpenicker Straße 126, 10179 Berlin, Deutschland

Leistung	Versand von Einladungen, E-Mail-Bestätigungen, Passwort-Zurücksetzen, Berichtsfreigaben, Erinnerungen und vertragsbezogenen Mitteilungen (z. B. Hinweis vor der Löschung von Videos nach Ende einer Video-Stufe); Führung einer Kontaktliste der bestätigten Konten für Support-Anfragen (keine Werbung)
Datenkategorien	Name und E-Mail-Adresse der Empfängerin oder des Empfängers, Inhalt der jeweiligen Nachricht; für die Support-Kontaktliste Name und E-Mail-Adresse des Kontos, gelöscht mit dem Konto
Ort der Verarbeitung	Europäische Union
Drittlandbezug	keiner
DPA	Die Auftragsverarbeitung ist Bestandteil der Brevo-Nutzungsbedingungen (https://www.brevo.com/legal/termsofuse/) und gilt mit deren Annahme

7. KI-gestützte Textauswertung

Dienstleister	Anthropic, PBC, 548 Market Street, PMB 90375, San Francisco, CA 94104, USA (support@anthropic.com) — Vertragspartner der Commercial Terms
Leistung	Erzeugung der Textauswertung zu Spiel, Spielerin, Mannschaft oder Turnier
Datenkategorien	Spiel- und Leistungskennzahlen, Ereignisse, Positionsdaten — **ohne Namen**, ersetzt durch bedeutungsfreie Kennungen
Ort der Verarbeitung	USA
Grundlage	EU-US Data Privacy Framework, soweit zertifiziert, im Übrigen Standardvertragsklauseln
Besonderheit	Anthropic verarbeitet die Daten nur zur Erbringung der Leistung und nach Weisung (DPA B.2, B.3); keine Verwendung zum Training von Modellen nach den Commercial Terms der API. Videobilder werden **nicht** übermittelt
DPA	Anthropic: Data Processing Addendum, gültig seit 24.02.2025, abgelegt unter docs/legal/dpa/anthropic-dpa-2025-02-24.pdf. Er ist Bestandteil der Commercial Terms und gilt **ohne gesonderte Unterschrift**; Anthropic ist Auftragsverarbeiter (B.1), Datenimporteur ist „the Anthropic entity that executed the Agreement“, die SCC (Modul 2/3) sind einbezogen, Unterauftragsverarbeiter werden vorab angekündigt (Widerspruch binnen 15 Tagen, C.3).

Weitere Empfänger, die keine Unterauftragsverarbeiter sind

Push-Dienste der Browser-Hersteller (Google, Apple, Mozilla). Aktiviert eine Nutzerin Push-Benachrichtigungen, wird die Nachricht über den Push-Dienst ihres eigenen Browsers zugestellt. Die Nutzlast ist Ende-zu-Ende verschlüsselt (Standard „Web Push", VAPID); der Dienst kennt den Inhalt nicht. Der Dienst wird nicht vom Anbieter ausgewählt, sondern vom Gerät der Nutzerin bestimmt.

Zahlungsdienstleister. Kostenpflichtige Pläne werden über Stripe (Stripe Payments Europe, Ltd., Dublin, Irland) abgerechnet, bei Zahlung mit PayPal zusätzlich über PayPal (Europe) S.à r.l. et Cie, S.C.A., Luxemburg. Sie erhalten **ausschließlich** die Vertrags- und Zahlungsdaten der Person, die den Plan bucht (Name, E-Mail-Adresse, Rechnungsanschrift, Zahlungsmittel) — keine Auftragsdaten des Vereins. Der

Anbieter verarbeitet diese Daten als eigener Verantwortlicher (§ 1 Abs. 3 des Vertrages), die Zahlungsdienstleister ebenfalls in eigener Verantwortung nach ihren Bedingungen.

Zuschauerinnen und Zuschauer öffentlicher Inhalte. Gibt der Verein einen Live-Ticker, einen Livestream oder einen Spielbericht öffentlich frei, sind die freigegebenen Inhalte für jede Person mit dem Link abrufbar (§ 12 Abs. 4 des Vertrages).

GitHub (Microsoft). Ein zeitgesteuerter Auftrag in GitHub Actions stößt jede Nacht die Recheninstanz der Datenbanksicherung (Ziffer 4) an. Er erhält dabei nur einen Zugangsschlüssel zum Starten dieser Instanz, keinen Zugang zur Datenbank, zum Videospeicher oder zu den Sicherungen, und verarbeitet keine Auftragsdaten. GitHub ist daher kein Unterauftragsverarbeiter.

Nicht eingesetzt werden:

- externe Dienste zur Erzeugung der Berichts-PDFs — diese entstehen in der Laufzeitumgebung der Anwendung selbst,
- Dienste zur Gesichtserkennung oder biometrischen Identifizierung,
- Werbe- oder Tracking-Netzwerke innerhalb der Anwendung.

Modelldateien (Personen-, Ball- und Texterkennung) werden beim Bau der Recheninstanz bzw. zu Beginn eines Auftrags aus öffentlichen Modellverzeichnissen geladen; dabei werden **keine** Auftragsdaten übermittelt.

Entwurfsstand: 12.11.2026 · Version 0.4 · nicht anwaltlich geprüft